DEV-14 · Endpoint Security Agent & MDR Escalation Standard

How many devices actually have a healthy agent reporting — and then who acts on an MDR case, in what time, on whose authority, and what closes it.

Field	Value
Document ID	DEV-14
Version	1.0 · Known Good edition, by Kevin Zelman
Catalogue domain	C. Device Usage
Operating tier	Tier 3 — Expert Services owns the agent estate and the MDR relationship. Tier 2 remediates unhealthy agents and executes containment within §6. Tier 4 authorises isolation above the §6 threshold and declares incidents under GOV-03.
Review cycle	Every six months, and after any change to the MDR service description.
Relationship to GOV-03	GOV-03 governs an incident once declared. This document governs everything before that: the telemetry, the agent, the MDR case, and the decision about whether a case becomes an incident. A case that becomes an incident hands over at GOV-03 §5 and is not then worked under two procedures in parallel.

1. Purpose

An MDR analyst raises a case at 02:40 concerning an organization device. Who reads it, how quickly, who is allowed to accept the containment recommendation, and what has to be true before the case can be closed? None of those four is written down, which means each is answered by whoever happens to be awake and available.

And before any of it, a question many organizations have never answered: how many of their devices actually have a healthy security agent reporting into the service at all? That is the number this document opens with, because every other commitment in it is conditional on it.

2. Coverage first — an MDR service is only as good as its telemetry

> **Every estate shows what happens to a device that is not online and healthy.**
>
> A common cutover plan: uninstall the old antivirus product, decrypt, and re-encrypt under Intune with Entra escrow. The usual outcome is that it only reaches machines that are online and healthy. Some devices end up with BitLocker keys in Entra and others with nothing.
>
> That work is not done badly. It simply cannot reach what is not there — and the estate does not tell anybody which devices those are.
>
> A security-agent estate has the identical failure mode and a worse consequence. A device with no healthy agent generates no telemetry, appears in no MDR case, and is therefore invisible in precisely the way that looks like safety. A quiet month is indistinguishable from a blind one.
>
> An agent installed but not reporting is worse than no agent at all, because it counts as coverage. DEV-02 condition 6 already says so; this document is where the number lives.
>
> An organization that has not measured agent coverage is paying for a managed detection service whose input it does not know. That is why §3 step 1 is the first numbered step in this document rather than a measurement section at the end.

3. Measuring coverage, and the path for a device that has stopped reporting

3.1 Producing the coverage number

1. PRODUCE THE NUMBER. Devices in the authoritative asset record (DEV-01 §10) as the denominator, against devices with an agent that has reported within the last 7 days as the numerator. State both figures and the ratio, with a date. Do not start from the security console: it can only show what reported, which makes the denominator wrong and the resulting number flattering.
2. RECONCILE THE TWO INVENTORIES, both directions. A device in the asset record and not in the console is the gap this document exists for. A device in the console and not in the asset record is also a finding — it is unmanaged, or it is somebody's personal machine, or it is a decommissioned device never removed (DEV-15).
3. CLASSIFY THE GAP, because the remediation differs entirely: never enrolled (DEV-01); enrolled but the agent never installed; agent installed and unhealthy; agent healthy but not reporting, which is usually network, proxy or an exclusion; and genuinely retired but never removed from the record.
4. SET AND PUBLISH THE TARGET: 98% of the managed Windows estate reporting within 7 days, measured monthly. Not 100% — devices are legitimately switched off for weeks, in a drawer, or in transit, and a 100% target makes the figure a fiction nobody investigates. 98% with a named list of the remainder is a number somebody can act on.
5. CHASE THE REMAINDER INDIVIDUALLY. This is the step that will not happen by itself, and it is the step that matters most. A silent device does not remediate itself and it does not appear as a failure — it simply does not appear.
6. GIVE THE NUMBER A STANDING HOME: the monthly position in §12, and the DEV-02 §10 three-number report. A coverage figure produced once for a meeting decays immediately.
7. ONLY THEN treat MDR case volume as meaningful. A quiet month on partial coverage is not a quiet month, and reporting it as one is worse than not reporting at all.

3.2 What a healthy agent means

- Installed, at a supported version.
- Real-time protection enabled.
- Threat intelligence and definitions current within 3 days.
- Reported to the service within the last 7 days.
- Tamper protection enabled.
- ONBOARDED TO THE MDR TENANT — not merely installed locally. This is the condition that gets missed, and a device that satisfies the first five and fails this one produces no case for the MDR provider to raise. It looks perfect in the local console.

3.3 Remediation for a device that has stopped reporting

Situation	Action	Owner	Timeframe
Not reported for 7–30 days	Automated remediation attempt — policy reapply, agent repair. Then Tier 2 outreach to the assigned user (DEV-01 §10).	Tier 2	Within the monthly cycle
Not reported for 30–60 days	Treated as non-compliant (DEV-02 condition 6). Tier 2 contacts the assigned user directly and books a fix.	Tier 2	5 coverage days
Not reported for more than 60 days and the user cannot be reached	Escalate to the department head. Consider whether the device is actually lost rather than unpatched (DEV-16), and say so plainly rather than leaving it on a list.	Tier 2 to Tier 3	10 coverage days
Tamper protection off, or real-time protection disabled	Treated as SUSPICIOUS, not as configuration drift. Disabling protection is what an attacker does first, and it is also what a user does when software will not install (DEV-11 §5.1).	Tier 3	Same coverage day
Agent present but not onboarded to the MDR tenant	Tier 3. This is a packaging or policy fault and it will not affect only one device — check the whole cohort.	Tier 3	2 coverage days
Device in the console but not in the asset record	Identify it. Unmanaged, personal, or decommissioned and never removed. Each has a different answer and none of them is “leave it”.	Tier 2	Within the monthly cycle

4. One agent, not two — moving to a single product

In this standard, Microsoft Defender for Endpoint is the endpoint protection product and the telemetry source for the MDR service. Where an older antivirus product is being removed and both are present on one device, that is a fault to be fixed, not defence in depth.

> **Two endpoint protection products on one device is a fault.**
> They scan each other's activity and quarantine each other's files. They produce false positives that consume exactly the triage capacity §9 depends on. They degrade the device enough that users start asking for exclusions, and an exclusion granted to make a machine usable is a hole granted for the wrong reason (§4.2).
> And the one that matters most: when something is blocked, it becomes ambiguous which product blocked it. That makes an incident timeline unreconstructable, which is the thing GOV-03 §6 exists to protect.
> Layering is a real principle and it is delivered at different layers — mail, identity, network, endpoint — not by two agents doing the same job on the same disk.

	Current state	Target state
Windows endpoints	Often mixed. Defender under Intune on the devices the transition reached; the old product's residue on the devices it did not, and an unknown number carrying both or neither.	Defender only, onboarded to the MDR tenant, tamper protection on, reporting within 7 days (§3.2).
macOS	Under test with enrollment. No published standard.	Per DEV-09 once written. Recorded as a gap, not assumed to be covered.
Servers, including core business systems	Confirm in writing that the MDR provider's scope includes every server, including those a vendor maintains. Servers are a common blind spot.	Onboarded, with server-appropriate policy and exclusions agreed with the system's vendor in writing rather than by convention (ACC-11). Record the exclusion list itself, per §4.2.
Lab, meeting-room and shared devices	Per the image, which means per whenever the image was last built.	Per DEV-06, and verified after each quiet-period rebuild (DEV-13 §5.2).

4.1 The removal rule

Removing the old agent and confirming the new one is healthy is ONE operation with one verification, not two tasks in a queue. A device with neither product is the worst possible outcome and it is precisely what doing them separately produces — the removal succeeds, the install is deferred, and nobody notices because the device has stopped reporting to both consoles.

4.2 Exclusions

- Every exclusion is a hole. It is recorded, owned, given an expiry, and approved by Tier 3.
- A vendor asking for a blanket directory or process-tree exclusion gets a specific path or a conversation. "Exclude the application folder" is a request to stop protecting the thing most likely to be attacked.
- Exclusions are reviewed with the age profile in §12. An old exclusion is a decision made about a version of the software that no longer exists.

5. The MDR relationship

This is the heart of the document. The division of labour is simple to state and is routinely blurred in practice, which is why it is stated.

The MDR provider does	The organization does
Detects, analyses, correlates and raises cases. Recommends containment. Acts within the pre-authorised set in §7.	Reads, decides, authorises, executes where the partner is not pre-authorised, verifies, and closes.
Provides expertise the organization does not staff and monitoring hours the organization does not cover.	Provides the context the partner cannot have: who is travelling, what migration is running this week, which scanning is sanctioned (§8).
Keeps its own case record.	Keeps the organization record, and ensures the two match (§9). An external case list that diverges from reality is worse than none (GOV-03 §8).
Does NOT declare an organization incident, communicate to the organization community, contact an end user, or decide organization risk.	Declares under GOV-03 §3, or records explicitly that no incident is declared and why.

5.1 Case severity and the organization's response commitment

The severity labels below are the organization's. The provider's own scale is mapped to them ONCE, in writing, and recorded in the MDR service description — not interpreted per case by whoever picks it up. Confirming that mapping is a specific action arising from this document.

Severity	What it typically means	Organization response commitment	Owner
CRITICAL	Confirmed compromise, ransomware indication, hands-on-keyboard activity, or containment already applied by the partner under §7.	Acknowledged within 15 minutes in coverage; 1 hour out of coverage via the §7 on-call path. Declared under GOV-03 §3, or a recorded decision that no incident is declared.	Tier 3
HIGH	Credible compromise of one account or one device, needing an organization decision.	Acknowledged within 1 coverage hour. Contained within §6 authority. Scope assessed before closure.	Tier 3
MEDIUM	Suspicious activity that needs context the partner does not have: a staff member travelling, a sanctioned scanning tool, an administrative action, a migration wave.	1 coverage day. Frequently closed by supplying the context — and the context is then given to the partner so the same case is not raised again (§8).	Tier 2, Tier 3 reviews
LOW / INFO	Hygiene findings, policy drift, vulnerability notifications.	The weekly review (§8). Vulnerability items go to DEV-13 §9 triage rather than being closed here.	Tier 2

One overriding rule: the organization's response is set by the ORGANIZATION'S assessment of impact, not by the partner's label. A partner Medium on the chief executive's laptop is not a Medium, and a partner Critical on a lab machine due for reimaging next week may genuinely be a High. The partner sees telemetry; the organization sees consequence.

- Every case gets a recorded organization outcome, including "no action, and here is why". A case closed on the partner's side with no organization record is a case the organization cannot account for later.

---

6. Authority — who accepts containment, and who may isolate

> **Authority is defined by tier and by impact, not by urgency.**
>
> Urgency argues for acting quickly. It does not say who is allowed to decide, and treating it as though it does is how a technician ends up making an institutional decision alone at three in the morning.
>
> Isolating the chief executive's laptop during a board meeting is a different decision from isolating a lab machine. The technical action is identical; the institutional consequence is not. What Tier 4 is deciding in that case is not whether the device is compromised — it is what to do in the next ten minutes about a person who is mid-commitment, and that requires a conversation IT should not be having on its own.
>
> So the matrix below is organised by WHAT is being contained, not by how urgent it feels.

Action	Authorised by	Executed by	Notes
Block a URL, domain, sender or file hash	Tier 3; Tier 2 in coverage for a phishing URL	Tier 2 or Tier 3	Low blast radius, reversible, and the most common containment there is (M365-22).
Disable sign-in and revoke sessions on an end-user account	Tier 3; Tier 2 in coverage on a confirmed compromise	Tier 2	Proportionate and time-limited (ACC-13 §4). The person is told through a channel independent of the affected account (GOV-03 §7).
Isolate a lab, meeting room, kiosk, presenter or loaner device	Tier 2	Tier 2	Nobody's individual work stops. Do it, record it, and reimage under DEV-15 §4.
Isolate a staff endpoint	Tier 3	Tier 2	The assigned user and their manager are told within the hour. Somebody has just lost their working day and should hear why from a person.
Isolate a device belonging to the chief executive, an executive, or anyone in a live governance or customer commitment	Tier 4 / Head of IT	Tier 3	The row this section exists for. Same technical action, different decision. The Head of IT weighs exposure against the institutional cost of the interruption; IT supplies the facts.

Action	Authorised by	Executed by	Notes
Isolate a server, or anything in a core business system	Tier 4, with the system owner; the system's vendor informed	Tier 3	Isolating a core business system is an organization outage. GOV-03 S1 candidate and a GOV-04 emergency change.
Disable an administrative identity or a break-glass account	Tier 4 only	Tier 3	ACC-07 §6. Never disabled by the partner, and never by automation.
Remote wipe a device	Tier 4 only	Tier 2	DEV-16 §5. Never an MDR decision and never pre-authorised (§7).
LIFT an isolation or re-enable an account	The tier that authorised it, or higher	Tier 2	Never by the technician who applied it, acting alone. And it is done promptly once resolved — an isolated device nobody revisits is a person who cannot work.

- WHERE THE AUTHORISING TIER CANNOT BE REACHED and the exposure is active, the most senior person available acts and informs the authoriser as soon as possible. This is the same rule GOV-03 §3 applies to declaration, for the same reason: a delayed containment is usually worse than a slightly over-broad one. Record who acted, and why the authoriser was not reached.
- Every isolation carries a stated maximum duration and a review point at the next coverage day. Containment is proportionate, fast and TIME-LIMITED (ACC-13 §4) — all three words, and the third is the one that gets forgotten.
- Containment is not punishment and it is not evidence of wrongdoing. Where the affected person is a member of staff or another end user, that distinction is made explicitly to them, because a disabled account feels like an accusation (ACC-13 §8).

7. The 24×7 problem, and what the MDR provider is pre-authorised to do

> **An unanswered 3am call is a decision by default.**
>
> The MDR provider watches around the clock. A small IT team does not staff around the clock, and GOV-06 §6 says so in the organization's own published commitments. Pretending otherwise produces the worst available outcome: a partner holding a containment recommendation, waiting for an authorisation that will not arrive until 08:30, with the compromise running in the meantime.
>
> A department that has not decided what the partner may do without waiting has still decided. It has decided that nothing happens until somebody wakes up, and it has done so without saying it out loud or telling anybody the cost.
>
> So the organization decides, in advance and in daylight, in the table below.

Action, out of coverage	Pre-authorised?	Conditions
Isolate a device on a high-confidence malware or ransomware detection	YES	Notify the on-call number and Tier 3 at the time of action. Reviewed at the start of the next coverage day, and not extended beyond that review without an organization decision.
Disable a compromised end-user account and revoke its sessions	YES	On a confirmed compromise, not on a suspicion. Same notification. Excludes administrative identities and break-glass accounts, which the partner never touches (ACC-07 §6).
Block a malicious URL, domain, sender or file hash	YES	Recorded, and reviewed at the weekly review (§8). Reversible and low cost to get wrong.
Isolate a server, or anything in a core business system	NO	Wake a human. On-call first, then the Head of IT. An outage decision on a core system is never taken by a partner, whatever the hour.
Isolate a device belonging to the chief executive or another executive	NO	Wake a human. §6 applies at 3am exactly as it applies at 3pm.
Remote wipe anything	NO, ever	DEV-16 §5. Tier 4 only, and irreversible actions are never pre-authorised.
Change a policy, an exclusion, or the monitoring configuration	NO	That is a change, and it enters the GOV-04 register (GOV-04 §8.1).
Contact an end user directly	NO	The organization communicates with its own people, in its own words (GOV-03 §7).

7.1 The on-call expectation, stated honestly

- One named on-call contact per week, with a documented rota and a real telephone number a person answers, plus a documented second. Not a shared mailbox — a mailbox is where an out-of-hours case goes to wait until morning.
- The on-call expectation is: ANSWER, decide within the §6 authority, and escalate to the Head of IT where the decision sits above it. It is not an expectation to remediate at 3am, and it should not be described as one.
- The on-call person records the decision in the morning. A verbal 3am authorisation with no record is indistinguishable, three months later, from nobody having been asked.
- THE UNCOMFORTABLE PART. An on-call rota across a small department is a real cost borne by a very small number of people. If the organization will not resource it, the honest answer is a BROADER pre-authorisation set — not an unstaffed rota that produces the unanswered call anyway. Choosing the second while describing the first is the worst of the three options.

> **Open question, with a named owner**
>
> The pre-authorisation set above and the on-call rota are both proposals until they are agreed with the provider and funded.
>
> ACTION 1: Head of IT to confirm the pre-authorised action list with the MDR provider IN WRITING and record it in the MDR service description, so that the partner's standing instructions and this document say the same thing. A provider cannot be expected to act on a table in an unapproved internal SOP.
>
> ACTION 2: Head of IT to decide whether the organization funds an on-call rota or accepts a broader pre-authorisation, and to record the decision either way.
>
> Owner: Head of IT. Until ACTION 2 is taken, the operative answer is the second — a broad de facto pre-authorisation by absence — whether or not anybody has said so. Which is exactly why it belongs in a document rather than in a habit.

---

8. The weekly MDR review, and keeping the partner's picture accurate

Most MDR services include a regular review, and it is the organization's main governance mechanism over the service. What it needs is a standing agenda and a record.

8.1 Standing agenda

- Open cases, with an organization outcome stated for each. Not a status — an outcome or a next action with an owner.
- Cases closed since the last review, and whether the two records match (§9).
- The coverage number (§3). Stated every week, because it is the figure that qualifies everything else in the meeting.
- The vulnerability position, by exception rather than in full (DEV-13 §9).
- Changes on the organization side the partner needs to know about (§8.3).
- Anything the partner has asked and not had answered. This item exists because of §8.2.
- Who is on call next week (§7.1).

8.2 Why keeping the partner current is an obligation of this document

A typical moment in a weekly review: the partner asks whether the organization is still using its old identity provider's MFA.

That is a fair and sensible question. The problem is when the organization cannot answer it from anything written down, and that the question needs asking at all. Both halves matter. It is evidence that the partner's picture of the estate has drifted from reality, and that the organization has no authoritative record with which to correct it.

A managed detection service reasons from a model of the environment. Where that model is stale, the service raises cases about normal activity and — far worse — fails to raise cases about activity that only looks normal against the old model. Keeping the partner's picture accurate is therefore not a courtesy. It is a control, and it belongs in this document.

8.3 What the partner is told, and when

- IDENTITY: which identity provider governs which population, and any change to it. ACC-03 §3 is the authoritative record.
- MIGRATION WAVES, before they run (DEV-01 §8). A wave produces exactly the anomalous enrollment and authentication patterns a detection service is built to flag.
- NEW APPLICATIONS WITH SSO, from the ACC-16 §10 register. A new federated sign-in source looks like new attack surface until somebody says otherwise.
- CHANGES TO THE AGENT ESTATE, exclusions or monitoring configuration — which are GOV-04 changes as well.
- SANCTIONED SCANNING, penetration testing, or a vendor remote session, BEFORE it happens rather than after the case is raised (ACC-11 §6).
- PEAK DATES AND THE FREEZE CALENDAR (GOV-04 §7.1). A partner scheduling anything into peak week is a problem the organization created by not telling them.
- The rule: tell the partner before, not after. It costs one line in a weekly meeting and saves an escalation at 3am.
- THE REVIEW IS MINUTED. A weekly meeting with no record lets the partner's picture drift again within six months, and nobody will be able to say when the drift started.

---

9. Case closure

A case closes when all eight of these are true. Fewer than eight is a case that has stopped being worked, which is a different thing.

1. THE ORGANIZATION HAS RECORDED AN OUTCOME: remediated; contained with no further action; no incident, with the reason; or escalated to GOV-03.
2. CONTAINMENT HELD. No further activity from the identity, device or infrastructure involved, across a stated observation period — 48 hours for a confirmed compromise.
3. SCOPE WAS ASSESSED, NOT ASSUMED. What else did this identity or device touch? One compromised account is rarely the whole picture (GOV-03 §5 step 6).
4. ANY ISOLATION OR ACCOUNT DISABLEMENT HAS BEEN LIFTED, or its continuation is recorded with a reason and a review date (§6).
5. THE AFFECTED PERSON HAS BEEN TOLD, through a channel independent of the affected account (GOV-03 §7). Including where the answer turned out to be nothing — especially then.
6. THE AGENT ON THE AFFECTED DEVICE IS HEALTHY AND REPORTING (§3.2). A remediated device that is now silent is not remediated; it is invisible.
7. THE PARTNER'S RECORD MATCHES THE ORGANIZATION'S. Closed on their side with the organization's outcome — not left open, and not closed with a guess (GOV-03 §8).
8. WHERE THE CAUSE WAS A CONTROL GAP, it is raised against the relevant SOP under GOV-01 §7 rather than remembered. Several documents in this catalogue exist by exactly that route.

9.1 What does not close a case

- The alert stopping. Alerts stop for many reasons, including the device going offline and the attacker becoming quieter.

- The user saying it is fine now.
- A reimage with no scope assessment. It removes the evidence and leaves the question — and if the credential was the route in, the reimage changed nothing (DEV-15 §4).
- A week passing. Age is not an outcome, in this document or in DEV-13 §9.3.

---

10. When a case becomes an incident, and when it becomes a person

10.1 Into GOV-03

- A case becomes an incident on the GOV-03 §2 test, and it is declared by a person at the organization. A partner case is not an organization declaration (GOV-03 §8).
- The handover is explicit: the case reference goes on the incident record, the incident lead takes it from GOV-03 §5, and the case is not worked in parallel under two procedures by two people.
- PRESERVE BEFORE YOU FIX (GOV-03 §6). Remediating an MDR case efficiently can destroy the evidence the incident then needs — revoking sessions and resetting a password is correct containment and it also removes much of the trail.

10.2 Into ACC-13

- A case becomes a person when the technical finding stops being a compromise and starts being conduct: sharing, selling, or deliberate misuse.
- That is a different document with a different authority and a different standard of evidence. The transition is a decision taken and recorded, not a drift that happens because the case notes got more confident each week.
- IT supplies the technical facts and does not draw conclusions about a person’s conduct (ACC-13 §9).

10.3 The archetype, and why it spans all three documents

A typical case: an account is blocked for the third time in a month. Several similar IP addresses have passed MFA on it, and account sharing is suspected. The person is told not to use a VPN or to share access with anyone.

Read as	It is
A DEV-14 case	Repeated authentication anomalies from related addresses on one identity. Triage, establish the cause, assess scope, contain proportionately. Appendix A, row 4.
A GOV-03 matter	At most S3 — a suspected compromise under investigation — unless exposure is confirmed. Declared, or explicitly not declared with the reason recorded.
An ACC-13 / ACC-15 matter	Potentially credential sharing, which is conduct. It goes to the person’s manager or department head, on evidence, through ACC-13 §3 and ACC-15 §5 — not from IT to the user.

> **The caution all three documents repeat, and it belongs here too**
>
> A repeat count is not evidence. A person travelling with their own device, or one with a single MFA method and an unreliable phone, produces a pattern that looks very like credential sharing — and treating them as a suspect is both wrong and corrosive to the relationship the service desk depends on (ACC-05 §2, ACC-15 §5).
>
> The MDR service will not make that distinction for the organization. It will surface the pattern, correctly, and the judgement stays with the organization. This is worth being clear about internally, because a partner's case notes carry an authority that can substitute for thinking.
>
> And the reason to write any of this down: cases like this are usually handled in a chat thread and a spoken instruction not to share access. The instruction is right, but it cannot be cited, and it leaves the organization with nothing to point at when the same account appears for a fourth time.

11. Service levels

Activity	Commitment (per GOV-06)
Critical case, in coverage	Acknowledged within 15 minutes — P1 (GOV-06 §5.2).
Critical case, out of coverage	The §7 on-call path. Partner acts within the pre-authorised set; organization acknowledgement within 1 hour.
High case	Acknowledged within 1 coverage hour.
Medium case	1 coverage day.
Low / informational	The weekly review. Vulnerability items to DEV-13 §9.
Containment of a confirmed account compromise	30 minutes from the decision (GOV-03 §10).
Tier 4 isolation decision for a §6 row requiring one	Within 30 minutes of the facts being established.
Lifting an isolation once the case is resolved	Same coverage day. Somebody is unable to work.
Agent health remediation	Per the §3.3 table.
Coverage number	Monthly, with the GOV-06 pack, and stated at every weekly review.
Weekly MDR review	On schedule, and minuted.

Anything at Critical overrides every GOV-06 target and capacity state, per GOV-03 §10. A capacity state cannot suppress a security matter (GOV-06 §7) — but it does affect how quickly everything else in this document happens, and the §12 out-of-coverage figure is where that shows.

12. Measurement

- AGENT COVERAGE: devices in the asset record against devices reporting within 7 days. Monthly. The headline number of this document and the first thing on the weekly agenda.
- Devices with an unhealthy agent, by fault class (§3.1 step 3).
- Devices with an agent present but NOT ONBOARDED to the MDR tenant. Should be zero and rarely is.
- Devices carrying two protection products (§4). Should be falling to zero on a stated curve.
- MDR cases by severity per month, each with a recorded organization outcome. A month with cases and no outcomes is not a report.
- Median time from case raised to organization acknowledgement, IN and OUT of coverage, reported separately. The out-of-coverage figure is the one that tells the truth about §7.
- Pre-authorised partner actions taken out of coverage, and how many were still judged correct at the next-day review. A high correctness rate is the argument for widening the pre-authorisation; a low one is the argument for funding the rota. This is the most useful number in the document and nobody currently produces it.
- Active exclusions, with age (§4.2).
- Cases that became GOV-03 incidents, and cases that became ACC-13 referrals. Both should be small; neither should be zero every quarter.

13. Records

Record	Held in	Retention
Monthly coverage number, with the device lists behind it	IT register	3 years
Agent health remediation actions	Ticket	1 year
MDR case log: reference, severity, organization outcome, owner, closed	IT register	3 years
Isolation and account-disablement authorisations: who, what, why, authoriser, lifted	Tier 4 record	3 years
Out-of-coverage partner actions and the next-day review of each	IT register	3 years
The pre-authorisation list as agreed with the MDR provider	MDR service description, and §7 of this document	Life of the contract
On-call rota	IT operational record	1 year
Weekly MDR review minutes	IT governance record	3 years
Exclusions register: device or path, reason, owner, expiry, approver	IT register	Life of the exclusion + 3 years
Cases escalated to GOV-03 or ACC-13	Per those documents	Per those documents

14. Related documents

ID	Title	Relationship
GOV-03	Security Incident Response & Escalation Matrix	Where a case goes when it becomes an incident. §8 there governs the partner relationship in an incident.
GOV-06	Service Commitments, Priority & Escalation	§6 coverage — the reason §7 exists at all.
GOV-04	IT Change Management & Maintenance Windows	Monitoring and exclusion configuration changes (§8.1 there).
DEV-02	Device Compliance & Configuration Baseline	Condition 6. This document is where its number lives.
DEV-13	Patch, Update & Maintenance Window Standard	Defender is the vulnerability input there and the protection agent here. §3 coverage determines whether the DEV-13 §9 input is complete.
DEV-01	Device Enrollment & Lifecycle	§10 — the asset record that is the coverage denominator.
DEV-15	Device Reassignment, Wipe, Retirement & Disposal	Decommissioned devices left in the console; reimaging after a case.
DEV-16	Lost, Stolen or Compromised Device Response	§5 wipe authority, and where a device silent for 60 days may actually belong.
DEV-09	macOS Device Management Standard	The provisional macOS row of §4.
DEV-11	Software Request, Approval, Licensing & Deployment	§5.1 there — software that brings its own protection component.
ACC-03	MFA Enrollment & Account Recovery	§3 — the authoritative record a partner will ask for.
ACC-07	Privileged & Administrative Account Standard	§6 — break-glass and administrative identities, never touched by the partner.
ACC-11	Vendor, Contractor & Consultant Account Standard	The MDR provider’s own access, and vendor sessions notified before rather than after.
ACC-13	Account Suspension for Misuse or Policy Investigation	§10.2 — where a case becomes a person.
ACC-15	Acceptable Use & Credential Sharing	§5 there — the ladder the §10.3 case actually belongs on.
ACC-05	Account Lockout Triage & Escalation	§2 — establish the cause before treating a repeat count as evidence.
M365-22	Phishing Reporting & Email Threat Response	The URL and sender blocks in §6.

Appendix A — MDR case triage and authority matrix

The one-page card. Find the row, act within it, escalate where it says so.

Case looks like	Owner	Contain how	Authorised by	Then
Ransomware or hands-on-keyboard indication, any device	Tier 3	Isolate immediately. Pre-authorised out of coverage (§7).	Tier 2 in coverage; MDR provider out of coverage	GOV-03 S1. Head of IT now, with incomplete information.
Confirmed account compromise, credentials used	Tier 3	Disable sign-in, revoke sessions, re-register all MFA methods.	Tier 3; Tier 2 in coverage; MDR provider out of coverage	GOV-03 §5. Preserve before you fix.
Malware detected and blocked by the agent, no execution	Tier 2	None. Verify agent health.	Tier 2	Close with the outcome recorded (§9).
Repeated authentication anomalies on one identity, related addresses	Tier 2, Tier 3 reviews	Proportionate: password reset and MFA re-registration before any disablement.	Tier 3	ACC-05 §2 first — establish the cause. ACC-13 only on evidence (§10.3).
Impossible travel or unfamiliar sign-in, single event	Tier 2	None pending context.	Tier 2	Ask the person. Close with the outcome, and tell the partner (§8).
Detection on the chief executive's or another executive's device	Tier 3	Isolation requires Tier 4. Not pre-authorised at any hour.	Head of IT	§6. Same technical action; different decision.
Detection on a core business system or other server	Tier 3	Never isolated without Tier 4.	Tier 4, with the system owner; the system's vendor informed	GOV-03 S1 candidate. GOV-04 emergency change.
Detection on a lab, meeting room, kiosk or loaner device	Tier 2	Isolate. Nobody's individual work stops.	Tier 2	Reimage (DEV-15 §4), then verify agent health.
Device has stopped reporting	Tier 2	Not a containment matter.	Tier 2	The §3.3 table. Beyond 60 days and unreachable, DEV-16.
Two protection products found on one device	Tier 2	Remove the old, confirm the new is healthy — one operation.	Tier 2	§4.1. Check the whole cohort, not just this device.
Sanctioned scanning or a vendor session the partner flagged	Tier 3	None.	Tier 3	Tell the partner BEFORE next time (§8.3, ACC-11 §6).

Case looks like	Owner	Contain how	Authorised by	Then
Daily vulnerability notification	Tier 3	Not a case.	Tier 3	DEV-13 §9 triage. Not closed by ageing out of the console.

Part of the Known Good SOP Catalog by Kevin Zelman, written for small IT shops, contractors and consultants, career-changers and help desk technicians. Adapt the names, tiers and times to your own shop: the times here are cushion, not a promise.